UNIVERSIDAD DE OCCIDENTE / INGENIERÍA EN SISTEMAS E INFORMÁTICA

OPERACIÓN TRAZABILIDAD

Guía paso a paso de entregables

Instrucciones de trabajo, plantillas, criterios de calidad y lista de verificación para construir la auditoría sin recibir las respuestas.

12 PASOS	15 PUNTOS	ALTO
RUTA DE TRABAJO	PONDERACIÓN	NIVEL

Curso: Auditoría de Sistemas

Docente: Ing. Herman Ávila

Fecha: Octubre de 2026

Institución: Universidad de Occidente, Guatemala

REGLA FUNDAMENTAL

Sin evidencia suficiente y pertinente no puede sostenerse un hallazgo. Las sospechas deben investigarse, no presentarse como hechos confirmados.

RUTA DE ENTREGA EN 12 PASOS

Esta guía explica **qué producir, cómo organizarlo y cómo revisar su calidad**. No contiene la solución del caso ni confirma quién ejecutó el ataque. Cada estudiante debe justificar sus conclusiones con evidencias identificables.

ENTREGA ESPERADA

Un informe PDF de 12–18 páginas (sin anexos), hojas de trabajo, evidencia y consultas SQL sintéticas, un resumen ejecutivo y una presentación. La nota total de este proyecto es de **15 puntos**.

Paso 1. Organizar el equipo y el expediente

- Elegir coordinador, responsable de evidencias, analista técnico y revisor de calidad; documentar quién ejecutará cada tarea.
- Crear un repositorio con control de versiones o una estructura de carpetas compartidas.
- Leer el caso completo; separar hechos declarados, evidencia inicial, hipótesis y vacíos de información.
- Crear un índice con los códigos E-01 a E-10, anotando dónde se evaluarán.

Producto: matriz RACI simple, cronograma y lista de información pendiente.

Paso 2. Formalizar el plan de auditoría

- Redactar objetivo general, al menos cuatro objetivos específicos, alcance temporal y técnico, exclusiones y limitaciones.
- Identificar interesados y procesos críticos: ventas, facturación, gestión de identidad, proveedores y continuidad.
- Definir criterios de evaluación a partir de documentos oficiales, políticas simuladas y contratos.
- Diseñar pruebas viables: inspección, conciliación, entrevistas simuladas, análisis SQL y observación de controles.

Producto: ficha de auditoría de una página, con firmas simuladas y cronograma.

Paso 3. Modelar la arquitectura y el flujo de negocio

- Dibujar interacciones CRM–SQL Server–ERP–móvil–nube–API–IA y distinguir componentes propios y del proveedor.
- Marcar fronteras de confianza, flujos de datos personales, usuarios internos/externos y administradores.
- Señalar dónde se generan logs, respaldos, cambios y autorizaciones.
- Definir los activos críticos y su relación con la operación.

Producto: un diagrama de arquitectura y otro de proceso comercial / tecnológico, con leyenda.

Paso 4. Crear la matriz de riesgos

- Extraer al menos 12 riesgos de las alertas y del entorno del caso; no copiar cada alerta como si fuera hallazgo.
- Asignar activo, amenaza, vulnerabilidad, consecuencia, P e I (escala 1–5) y control esperado.
- Calcular nivel inherente; valorar diseño/ejecución de control con justificación; estimar riesgo residual.
- Ordenar el Top 5 por relevancia y explicar cualquier cambio de priorización.

Producto: hoja de cálculo y una explicación ejecutiva de los cinco riesgos principales.

PLANTILLA A · Matriz de riesgos

ID	Activo y amenaza	Debilidad / efecto	P × I	Control / residual
R-01	[Completar]	[Completar]	[1–5] × [1–5]	[Completar]
R-02	[Completar]	[Completar]	[1–5] × [1–5]	[Completar]

Se recomienda agregar columnas de responsable, fuente, probabilidad, impacto, tipo de control, diseño, operación y riesgo residual.

Paso 5. Crear el programa de auditoría y controles

- Cubrir ITGC: accesos, segregación, gestión de cambios, operaciones, respaldos y monitoreo.
- Cubrir controles de aplicaciones y desarrollo: validaciones, permisos, API, pruebas, despliegues y trazabilidad.
- Cubrir TPRM/cloud, datos personales, SLA, continuidad e IA.
- Diseñar al menos una prueba y evidencia esperada para cada control prioritario.

PLANTILLA B · Programa de pruebas

Prueba	Riesgo	Procedimiento verificable	Evidencia	Criterio
T-01	R-[ ]	[Qué revisar, cómo y con qué muestra]	E-[ ]	[Norma/política]
T-02	R-[ ]	[Qué revisar, cómo y con qué muestra]	E-[ ]	[Norma/política]

Paso 6. Preparar los papeles de trabajo y custodia

- Para cada evidencia E-01 a E-10: indicar origen, fecha, custodio, integridad y relación con pruebas.
- Anotar método de obtención y limitación; conservar copia original y trabajar sobre una copia de laboratorio.
- Calcular hash SHA-256 para archivos obtenidos o generados cuando tenga sentido, documentando herramienta y momento.
- No marcar una observación como hallazgo hasta contrastarla contra un criterio aplicable.

PLANTILLA C · Papel de trabajo

Campo	Contenido que debe completar el estudiante
Código / objetivo	PT-XX · finalidad de la prueba.
Vínculos	Riesgo R-XX · prueba T-XX · evidencia E-XX.
Fuente / fecha / custodio	Origen del documento, fecha, cómo se obtuvo, responsable.
Procedimiento	Pasos reproducibles, alcance y muestra.
Resultado	Qué dato se verificó y qué limitaciones existen.
Conclusión	Cumple / no cumple / no concluyente, con justificación.

Paso 7. Ejecutar análisis SQL sobre datos sintéticos

- Crear tablas relacionadas de ejemplo: Usuarios, Sesiones, Privilegios, Ordenes, HistorialOrdenes, CambiosSistema y Backups.
- Generar registros ficticios coherentes con el caso; documentar supuestos y definir claves primarias/foráneas.
- Construir seis o más consultas SELECT para buscar permisos excesivos, bajas pendientes, horarios anómalos, modificaciones, duplicidades y variaciones de backup.
- Adjuntar cada sentencia, evidencia del resultado y explicación; distinguir lo que el resultado sugiere de lo que prueba.
- Realizar análisis de datos adicional en Excel/Python (opcional): duplicados, concentraciones, valores atípicos y discrepancias.

Producto: archivo .sql reproducible, diagrama entidad–relación, diccionario mínimo y tabla de resultados. No usar INSERT/UPDATE/DELETE sobre datos de terceros.

Paso 8. Reconstruir el incidente y evaluar continuidad

- Reconstruir la cronología de la página del caso, clasificando cada evento según fuente, fiabilidad y tiempo.
- Formular mínimo dos hipótesis alternativas de secuencia de ataque, marcando evidencia a favor/en contra.
- Analizar alertas, desincronización horaria posible y lagunas de logs. Explicar qué sería necesario obtener para confirmar exfiltración.

- Revisar BIA, RTO, RPO, restauración, evidencia de integridad y criterios para devolver el servicio a producción.
- Separar funciones: la administración y su equipo de respuesta ejecutan la contención; el auditor evalúa y recomienda sin perder independencia.

Producto: línea de tiempo, mapa causal con grados de certeza y evaluación de continuidad.

Paso 9. Auditar terceros, cumplimiento e IA

- Comparar SLA contractual, indisponibilidad real y objetivos de negocio derivados del BIA; no suponer que coinciden.
- Revisar debida diligencia, subcontratistas, reportes de certificación, accesos del proveedor y plan de salida de información.
- Determinar qué normas jurídicas y obligaciones contractuales aplican realmente, citando artículo, vigencia y fuente cuando corresponda.
- Examinar al chatbot por exactitud, protección de información, permisos, registros, revisión humana y susceptibilidad a entradas engañosas.
- Proponer pruebas de control sobre entorno ficticio y explicar cómo se evitaría exponer datos de clientes.

Producto: ficha TPRM, tabla de responsabilidad compartida, evaluación de privacidad y ficha de riesgos de IA.

Paso 10. Redactar y validar cinco hallazgos

- Redactar al menos cinco hallazgos distintos; no duplicar la misma causa raíz con otro título.
- Incluir condición, criterio específico, causa razonada, efecto/riesgo, evidencia, recomendación y prioridad.
- Marcar “no concluyente” cuando la evidencia no alcance para afirmar el incumplimiento.
- Pedir a otro integrante que cuestione cada hallazgo como si fuese el auditado y revisar el lenguaje.

PLANTILLA D · Hallazgo auditable

Elemento	Guía de redacción (sin respuesta)
Código y título	H-XX · título claro y específico.
Condición	Qué se observó y en cuál período o muestra.
Criterio	Qué requisito o buena práctica esperaba otro resultado.
Causa	Por qué ocurrió; indicar si es causa probada o hipótesis.
Efecto / riesgo	Consecuencia demostrada o potencial, sin exagerar.
Evidencia	ID, prueba y fragmento verificable.
Recomendación	Acción implementable, no declaración genérica.
Prioridad	Justificación relativa a probabilidad e impacto.

Paso 11. Diseñar el plan de acción y validación

- Organizar acciones por 0–24 h, 24–72 h, 7–30 días y 30–90 días.
- Vincular acciones a cada H-XX y prever dependencias (por ejemplo preservar evidencias antes de alterar sistemas).
- Distribuir Q350,000 de presupuesto ficticio y justificar prioridades, recursos, decisiones diferidas y riesgos aceptados.
- Definir KPI, evidencia de ejecución, procedimiento de reauditoría y riesgo residual.
- Explicar mecanismos para verificar que los controles sigan operando 30 y 90 días después.

PLANTILLA E · Plan correctivo y preventivo

Hallazgo	Acción	Responsable / plazo	Costo Q	KPI + cierre
H-[ ]	[Medida concreta]	[Rol] / [fecha]	[Q]	[Métrica y prueba]
H-[ ]	[Medida concreta]	[Rol] / [fecha]	[Q]	[Métrica y prueba]

Paso 12. Emitir informe y defenderlo

- Preparar resumen ejecutivo de máximo una página: riesgos Top 5, impacto, decisiones solicitadas y estado del riesgo residual.
- Presentar alcance, metodología, matrices, evidencias, hallazgos y plan priorizado en un PDF de 12–18 páginas sin anexos.
- Diseñar exposición de hasta 12 minutos: situación, método, conclusiones, decisiones y métricas; no leer toda la presentación.
- Preparar respuestas a contradicciones: transferencia legítima vs fuga, evidencias incompletas, SLA vs BIA, aprobación verbal y recuperación vs cadena de custodia.
- Realizar revisión cruzada final de citas, ortografía, sumas, identificadores y consistencia entre anexos e informe.

Producto: informe final, resumen ejecutivo, presentación y declaración de uso de IA.

FORMATO DE ENTREGA Y ESTRUCTURA DE CARPETAS

Carpeta/archivo sugerido	Contenido
01_Informe/Informe_Final.pdf	Documento técnico central (12–18 páginas sin anexos).
02_Matrices/Matriz_Riesgos.xlsx	Riesgos inherentes/residuales, controles y programa de pruebas.
03_Evidencias/Papeles_Trabajo.pdf	Custodia, códigos E-XX, resultados y verificaciones.
04_SQL/Analisis_Auditoria.sql	DDL y consultas de solo lectura más datos sintéticos.
05_Plan/Plan_Accion.xlsx	Acciones, responsables, Q350,000, KPI y cierre.
06_Comite/Resumen_y_Presentacion.pdf	Decisiones ejecutivas y defensa.
07_Referencias/Uso_IA.pdf	Fuentes, versiones y registro de uso de IA.

Declaración de uso de inteligencia artificial

Campo	Qué se documenta
Herramienta	Modelo o servicio utilizado.
Prompts	Preguntas relevantes tal como se formularon.
Resultado empleado	En qué sección ayudó y con qué límites.
Validación humana	Fuente consultada, cálculo reejecutado o prueba independiente.
Ediciones / aprendizaje	Qué cambió el estudiante y qué aprendió.

LISTA DE VERIFICACIÓN PARA ANTES DE ENTREGAR

- ☐ El informe diferencia hechos, hipótesis, supuestos y datos no disponibles.
- ☐ Se incluyeron 12 o más riesgos y se justificó el Top 5.

- ☐ Cada control significativo se vincula a prueba, criterio y evidencia.
- ☐ La base de datos es ficticia y hay por lo menos seis consultas SELECT reproducibles.
- ☐ La cronología del incidente contiene fuentes, horario y límites de certeza.
- ☐ Se evaluó ITGC, aplicaciones, BD, SDLC/cambios, nube, TPRM, privacidad, BIA y chatbot IA.
- ☐ Se presentaron al menos cinco hallazgos completos, sin inventar evidencia.
- ☐ Cada acción incluye responsable, plazo, presupuesto, KPI y verificación de efectividad.
- ☐ La suma presupuestada no supera Q350,000, o se justifica expresamente cualquier exceso.
- ☐ La suma de la rúbrica equivale a 15 puntos.
- ☐ Las fuentes y sus versiones son verificables y el uso de IA está declarado.
- ☐ La presentación puede defenderse aun cuando el comité cuestione la hipótesis principal.

Rúbrica resumida del docente

Bloque	Puntos
Planeación	1.0
Riesgos	2.0
Controles ITGC, aplicaciones y BD	2.0
Forense y trazabilidad	2.5
Terceros, privacidad y cumplimiento	1.5
Hallazgos	1.5
Contención y recuperación	1.5
Prevención, IA y seguimiento	1.5
Informe y defensa	1.5
TOTAL	**15.0**

CRITERIO DE CALIDAD

La auditoría debe construir una cadena coherente y verificable: **riesgo → control → prueba → evidencia → hallazgo → acción → KPI → validación del riesgo residual.**